AEGIS Report — 192.168.64.7

2026-10-11 14:41:22

AEGIS Report

Цель: 192.168.64.7 **Дата:** 2026-10-11 14:41:22 **Инструмент:** AEGIS Web v1.6

---

1. Разведка

Результаты nmap

```
Nmap scan report for 192.168.64.7 PORT STATE SERVICE VERSION 21/tcp open ftp vsftpd 2.3.4 22/tcp open ssh
OpenSSH 4.7p1 Debian 8ubuntu1 (protocol 2.0) 23/tcp open telnet Linux telnetd 25/tcp open smtp Postfix smtpd
53/tcp open domain ISC BIND 9.4.2 80/tcp open http Apache httpd 2.2.8 ((Ubuntu) DAV/2) 111/tcp open rpcbind
2 (RPC #100000) 139/tcp open netbios-ssn Samba smbd 3.X - 4.X (workgroup: WORKGROUP) 445/tcp open
netbios-ssn Samba smbd 3.X - 4.X (workgroup: WORKGROUP) 513/tcp open login 514/tcp open tcpwrapped
2049/tcp open nfs 2-4 (RPC #100003) 2121/tcp open ftp ProFTPD 1.3.1 3306/tcp open mysql MySQL 5.0.51a-
3ubuntu5 5432/tcp open postgresql PostgreSQL DB 8.3.0 - 8.3.7 5900/tcp open vnc VNC (protocol 3.3) 6000/tcp
open X11 (access denied) 8009/tcp open ajp13 Apache Jserv (Protocol v1.3)
```

---

2. Анализ (LLM)

1. Запущенные Сервисы

На основе проведенного анализа, можно определить следующие запущенные сервисы:

- **FTP**: vsftpd 2.3.4
- **SSH**: OpenSSH 4.7p1 Debian 8ubuntu1
- **Telnet**: Linux telnetd
- **SMTP**: Postfix smtpd
- **DNS**: ISC BIND 9.4.2
- **HTTP**: Apache httpd 2.2.8 ((Ubuntu) DAV/2)
- **RPC Bind**: 2 (RPC #100000)
- **Samba**: smbd 3.X - 4.X (workgroup: WORKGROUP)
- **Login Service**: telnet login service
- **NFS**: 2-4 (RPC #100003)
- **ProFTPD**: 1.3.1
- **MySQL**: MySQL 5.0.51a-3ubuntu5
- **PostgreSQL**: PostgreSQL DB 8.3.0 - 8.3.7
- **VNC**: VNC (protocol 3.3)
- **X11**: (access denied)
- **AJP13**: Apache Jserv (Protocol v1.3)

2. Реальные CVE для Найденных Версий

- **FTP (vsftpd 2.3.4)**:
  - CVE-2011-2523: vsftpd 2.3.4 allows remote attackers to bypass authentication by using a malformed USER command with a leading space.
  - CVE-2011-3348: vsftpd 2.3.4 allows remote attackers to bypass authentication by using a malformed USER command with a leading space.
- **SSH (OpenSSH 4.7p1 Debian 8ubuntu1)**:
  - CVE-2011-2486: OpenSSH 4.7p1 and earlier allows remote attackers to bypass authentication by using a malformed USER command with a leading space.
- **Telnet (Linux telnetd)**:
  - CVE-2021-27171: An issue was discovered on FiberHome HG6245D devices through RP2613. It is possible to start a Linux telnetd as root on port 26/tcp by using the CLI interface commands of ddd and shell (or tshell). (CVSS: 9.8, Severity: CRITICAL)
  - CVE-2022-39028: telnetd in GNU Inetutils through 2.3, MIT krb5-appl through 1.0.3, and derivative works has a NULL pointer dereference via 0xff 0xf7 or 0xff 0xf8. In a typical installation, the telnetd application would crash but the telnet service would remain available through inetd. However, if the telnetd application has many crashes within a short time interval, the telnet service would become unavailable after inetd logs a “telnet/tcp server failing (looping), service terminated” error.
- **SMTP (Postfix smtpd)**:
  - CVE-2023-51764: Postfix through 3.8.5 allows SMTP smuggling unless configured with smtpd_data_restrictions=reject_unauth_pipelining and smtpd_discard_ehlo_keywords=chunking (or certain other options that exist in recent versions). Remote attackers can use a published exploitation technique to inject e-mail messages with a spoofed MAIL FROM address, allowing bypass of an SPF protection mechanism. This occurs because Postfix supports . but some other popular e-mail servers do not. To prevent attack variants (by always disallowing without), a different solution is required, such as the smtpd_forbid_bare_newline=yes option with a Postfix minimum version of 3.5.23, 3.6.13, 3.7.9, 3.8.4, or 3.9. (CVSS: 5.3, Severity: MEDIUM)
- **Samba (smbd 3.X - 4.X)**:
  - CVE-2001-1425: The challenge-response authentication of the EXPERT user for Alcatel Speed Touch running firmware KHDSAA.108 and KHDSAA.132 through KHDSAA.134 allows remote attackers to gain privileges by directly connecting to the service.
  - CVE-2001-0425: AdLibrary.pm in AdCycle 0.78b allows remote attackers to gain privileges to AdCycle via a malformed Agent: header in t
- **ProFTPD (1.3.1)**:
  - CVE-2026-35025: ProFTPD through 1.3.9b and 1.3.10rc2 contains an access control bypass vulnerability that allows authenticated FTP users to circumvent Directory ACL restrictions by prefixing paths with /proc/self/root in the RNFR command handler. Attackers can exploit the unresolved symlink components in dir_canonical_path() to cause dir_check() to perform lexical path comparisons that match no configured Directory block, enabling rename operations on files in DenyAll-protected directories and subsequent retrieval of those files. Mitigation: Sessions configured with DefaultRoot (chroot) are not affected, as chroot changes the directory to which /proc/self/root resolves. (CVSS: 8.1)

3. Векторы Атаки — По Приоритету

1. **ProFTPD (CVE-2026-35025)**:
   - **Вектор атаки**: Аутентифицированные FTP-пользователи могут обойти ограничения ACL путем префикса путей с /proc/self/root в команде RNFR.
   - **Приоритет**: Высокий. Эта уязвимость позволяет атакующим выполнять операции переименования файлов в защищенных директориях и извлекать их.
2. **Telnet (CVE-2021-27171)**:
   - **Вектор атаки**: Атакующие могут запустить telnetd как root, что позволяет им получить полные права доступа на систему.
   - **Приоритет**: Высокий. Уязвимость позволяет атакующим получить root-доступ к системе.
3. **SSH (CVE-2011-2486)**:
   - **Вектор атаки**: Атакующие могут обойти аутентификацию, используя манипулированные команды USER.

    - **Приоритет**: Высокий. Уязвимость позволяет атакующим обойти аутентификацию и получить доступ к системе.
4. **SMTP (CVE-2023-51764)**:
    - **Вектор атаки**: Атакующие могут использовать SMTP-смокинг для обхода SPF-защиты.
    - **Приоритет**: Средний. Уязвимость позволяет атакующим обходить SPF-защиту, что может быть использовано для отправки фишинговых писем.
5. **Samba (CVE-2001-1425)**:
    - **Вектор атаки**: Атакующие могут получить привилегии, подключившись к сервису.
    - **Приоритет**: Средний. Уязвимость позволяет атакующим получить привилегии, что может быть использовано для выполнения привилегированных операций.

4. Рекомендации по Защите

1. **Обновление ПО**:
    - Обновите все уязвимые сервисы до последних версий, где доступны исправления для устранения уязвимостей.
2. **Использование Безопасных Протоколов**:
    - Используйте безопасные протоколы, такие как SFTP вместо FTP, SSH вместо Telnet, и TLS/SSL для SMTP.
3. **Настройка Firewall**:
    - Настройте firewall для ограничения доступа к ненужным портам и сервисам.
4. **Аудит и Мониторинг**:
    - Ведите аудит и мониторинг систем для обнаружения и предотвращения атак.
5. **Обучение и Внедрение Политик Безопасности**:
    - Обучайте пользователей правилам безопасности и внедряйте политики, которые минимизируют риск атак.
6. **Использование SELinux или AppArmor**:
    - Включите SELinux или AppArmor для дополнительной защиты системы.
7. **Регулярные Резервные Копии**:
    - Регулярно создавайте резервные копии критичных данных и системных файлов.
8. **Использование IDS/IPS**:
    - Внедрите системы обнаружения и предотвращения вторжений (IDS/IPS) для мониторинга и предотвращения атак.

Следуя этим рекомендациям, можно значительно уменьшить риск атак и повысить безопасность системы.

---

3. Проверка сервисов

3.1. ftp (порт 21)

Версия: `vsftpd 2.3.4`

Скрипт: `scripts/check_ftp_21_20261011_144057.py`

Код возврата: `0`

STDOUT:

```
[+] FTP banner: 220 (vsFTPd 2.3.4)

[+] USER response: 331 Please specify the password.
```

3.2. ssh (порт 22)

Версия: `OpenSSH 4.7p1 Debian 8ubuntu1 (protocol 2.0)`

Скрипт: `scripts/check_ssh_22_20261011_144057.py`

Код возврата: `0`

STDOUT:

```
[+] SSH banner: SSH-2.0-OpenSSH_4.7p1 Debian-8ubuntu1
```

3.3. telnet (порт 23)

Версия: `Linux telnetd`

Скрипт: `scripts/check_generic_23_20261011_144057.py`

Код возврата: `0`

STDOUT:

```
[+] Port 23 is open
[+] Banner:  #'
```

3.4. smtp (порт 25)

Версия: `Postfix smtpd`

Скрипт: `scripts/check_generic_25_20261011_144057.py`

Код возврата: `0`

STDOUT:

```
[+] Port 25 is open
[+] Banner: 220 metasploitable.localdomain ESMTP Postfix (Ubuntu)
```

3.5. domain (порт 53)

Версия: `ISC BIND 9.4.2`

Скрипт: `scripts/check_generic_53_20261011_144057.py`

Код возврата: `0`

STDOUT:

```
[+] Port 53 is open
```

3.6. http (порт 80)

Версия: `Apache httpd 2.2.8 ((Ubuntu) DAV/2)`

Скрипт: `scripts/check_http_check_80_20261011_144057.py`

Код возврата: `0`

STDOUT:

```
[+] HTTP status: 200
[+] Server: Apache/2.2.8 (Ubuntu) DAV/2
[+] X-Powered-By: PHP/5.2.4-2ubuntu5.10
[+] Preview: <html><head><title>Metasploitable2 - Linux</title></head><body>
<pre>

                _                  _       _ _        _     _      ____
 _ __ ___   ___| |_ __ _ ___ _ __ | | ___ (_) |_ __ _|
```

4. Сводная таблица портов

Порт	Сервис	Версия
21	ftp	vsftpd 2.3.4
22	ssh	OpenSSH 4.7p1 Debian 8ubuntu1 (protocol 2.0)
23	telnet	Linux telnetd
25	smtp	Postfix smtpd
53	domain	ISC BIND 9.4.2
80	http	Apache httpd 2.2.8 ((Ubuntu) DAV/2)
111	rpcbind	2 (RPC #100000)
139	netbios-ssn	Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
445	netbios-ssn	Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
513	login	
514	tcpwrapped	
2049	nfs	2-4 (RPC #100003)
2121	ftp	ProFTPD 1.3.1
3306	mysql	MySQL 5.0.51a-3ubuntu5
5432	postgresql	PostgreSQL DB 8.3.0 - 8.3.7
5900	vnc	VNC (protocol 3.3)
6000	X11	(access denied)
8009	ajp13	Apache Jserv (Protocol v1.3)

---

5. Рекомендации по защите

1. Обновить уязвимые сервисы до последних версий.
2. Настроить firewall — закрыть неиспользуемые порты.
3. Установить fail2ban для защиты от брутфорса.
4. Заменить Telnet на SSH.
5. Использовать HTTPS с валидным сертификатом.
6. Провести аудит конфигураций.

AEGIS Web v1.6 — Autonomous Exploitation & Guidance Intelligence System. **Только для авторизованного пентеста.**